Security & Privacy Disclosure, Final Report

DeepSeek Android (com.deepseek.chat)

The core chat function processes EU user prompts in the People’s Republic of China, DeepSeek replied once with a legal argument on one finding and an operational claim on two more, four findings and three follow-up questions remain unanswered at publication

PUBLIC DISCLOSURE, 17 OCTOBER 2026: EMBARGO REACHED 30 SEPTEMBER 2026, ONE REPLY RECEIVED, FOUR FINDINGS AND THREE QUESTIONS UNANSWERED

Target	Hangzhou DeepSeek Artificial Intelligence Co., Ltd. (operator per DeepSeek privacy policy), registered address in Beijing per the Prighter verification registry
Package	com.deepseek.chat v2.2.0 (versionCode 230)
Platform Audited	Android, static analysis of the production APK set
Initial Disclosure (R1)	2026-07-02, to privacy@deepseek.com and rep_deepseek@prighter.com, CC Austrian Datenschutzbehörde and EDPS
Disclosure / Embargo Date	2026-09-30
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	8 (1 Critical, 3 High, 3 Medium, 1 Low)
Correspondence	7 messages sent by RFI-IRFOS (2026-07-02 to 2026-08-15), 1 reply received (2026-08-07, 36 days after disclosure), 1 rebuttal and 1 further follow-up sent, no reply after 2026-08-07
Authorities Notified	Austrian Datenschutzbehörde (dsb@dsb.gv.at), European Data Protection Supervisor (edps@edps.europa.eu), in CC
SHA-256 (base APK)	`1f316c5a544bc1aa5a5cc4c1ee9a55e3eeb19e39f2acbfc20812b6be31403361`

security@rfi-irfos.com • rfi-irfos.com
ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 DeepSeek's Reply and RFI-IRFOS's Response 6

5 Findings 6
- 5.1 C1: Core chat function routes EU user prompts to chat.deepseek.com, and the operator's own policy states Personal Data is processed and stored in the People's Republic of China . . . 7
- 5.2 H1: Two ContentProviders initialise at process start, before any consent screen can render . . . 8
- 5.3 H2: Eight-vendor Chinese third-party SDK chain, self-disclosed in DeepSeek's zh-CN compliance list and matched to the binary . . . 9
- 5.4 H3: network_security_config.xml permits cleartext traffic app-wide and contradicts the manifest declaration . . . 10
- 5.5 M1: Named-vendor disclosure exists only for zh-CN users; the en-US policy names no recipients . . . 10
- 5.6 M2: "Not designed or intended to process sensitive Personal Data" disclaimer against an unfiltered free-text chat interface with opt-out model training . . . 11
- 5.7 M3: Hardcoded SDK AppKey and AppSecret in AndroidManifest meta-data . . 11
- 5.8 L1: Age gate relies on self-declared birth date; effective minimum age 14 . . . 11

6 Impact Analysis 12

7 The Complete Chain: Seven Messages, One Reply, Three Open Questions 12

8 Data Protection: Article by Article 13

9 Regulatory & Legal Landscape 13

10 Indicators of Compromise 14

11 Disclosure Timeline & Outcome 14

12 Residual Risk & Recommendations 15

Executive Summary

DeepSeek's Android client is the official app for its conversational AI service. A static analysis of the production APK v2.2.0 (base.apk sha-256 1f316c5a...403361) found that the core chat function sends every user prompt to chat.deepseek.com, and that DeepSeek's own privacy policy states Personal Data is directly collected, processed and stored in the People's Republic of China. Binary and policy describe the same processing, so C1 rests on two independent evidence classes.

Three further high-severity findings concern two ContentProviders that initialise at process start before any consent screen (H1), an eight-vendor Chinese third-party SDK chain that DeepSeek itself lists in its zh-CN compliance documents (H2), and a network security configuration that permits cleartext traffic app-wide against the manifest's own declaration (H3). Three medium findings and one low finding cover transparency asymmetry between language versions, the sensitive-data disclaimer, a hardcoded SDK secret and a self-declared age gate. The report also records what DeepSeek did well: a verified EU Art. 27 representative, no location permission, no Western advertising SDK and no Firebase key.

RFI-IRFOS disclosed on 2 July 2026 with an embargo of 30 September 2026 and followed up on 6 July, 17 July, 23 July and 31 July. On 7 August 2026 privacy@deepseek.com replied once. The reply cited EDPB Guidelines 05/2021 paragraph 18 to characterise the processing as direct collection, stated that the carrier SDKs and the Volcano SDK are not triggered for EU users, and stated that a DPIA and an LIA were drafted. RFI-IRFOS verified the EDPB citation and confirms it is accurate.

The reply left H1, H3, M1 and M3 unaddressed. RFI-IRFOS answered the same day and asked three narrow questions, then repeated them on 15 August 2026. No further reply arrived. The embargo passed on 30 September 2026, and this report publishes 17 days later with the record as it stands: seven messages sent, one reply received, three questions open. Any substantive answer will be added to the public record next to the original findings.

ID	Severity	Title
C1	CRITICAL	Core chat function routes EU user prompts to chat.deepseek.com, and the operator's own policy states Personal Data is processed and stored in the People's Republic of China
H1	HIGH	Two ContentProviders initialise at process start, before any consent screen can render
H2	HIGH	Eight-vendor Chinese third-party SDK chain, self-disclosed in DeepSeek's zh-CN compliance list and matched to the binary
H3	HIGH	network_security_config.xml permits cleartext traffic app-wide and contradicts the manifest declaration
M1	MEDIUM	Named-vendor disclosure exists only for zh-CN users; the en-US policy names no recipients
M2	MEDIUM	"Not designed or intended to process sensitive Personal Data" disclaimer against an unfiltered free-text chat interface with opt-out model training

ID	Severity	Title
M3	MEDIUM	Hardcoded SDK AppKey and AppSecret in AndroidManifest meta-data
L1	LOW	Age gate relies on self-declared birth date; effective minimum age 14

Subject & Operator Context

The operator named in DeepSeek's privacy policy is Hangzhou DeepSeek Artificial Intelligence Co., Ltd. The EU Art. 27 representative is Prighter Group (Prighter EU Rep GmbH), contact rep_deepseek@prighter.com, independently verifiable on Prighter's public registry. The registry lists a Beijing address for the operator, which differs from the Hangzhou company name. RFI-IRFOS did not resolve that discrepancy. No EU main establishment exists, so the Austrian Datenschutzbehörde acts as the home and initiating supervisory authority. The app is subscription-funded through Google Play Billing, and no advertising or attribution SDK from a Western vendor was found.

Engagement Summary

RFI-IRFOS sent the initial disclosure on 2 July 2026 to privacy@deepseek.com and to the Art. 27 representative, with the Austrian Datenschutzbehörde and the EDPS in CC, stating an embargo date of 30 September 2026. The letter asked three questions: which legal basis and technical measure ensures consent precedes processing, whether the DPO had been briefed, and whether a DPIA under Art. 35 exists.

Follow-ups on 6 July, 17 July, 23 July and 31 July 2026 restated the findings and questions. On 7 August 2026 privacy@deepseek.com replied with a substantive message signed DeepSeek Team. It cited the policy section on data storage location, EDPB Guidelines 05/2021 paragraph 18, the activation conditions of the carrier and Volcano SDKs, and the existence of a DPIA and an LIA.

RFI-IRFOS replied the same day. It confirmed the citation, explained that provider initialisation does not depend on login method, listed the four findings the reply did not address, and asked three questions. The 15 August 2026 follow-up repeated them. Neither the direct address nor the Art. 27 representative answered after 7 August 2026.

DeepSeek's Reply and RFI-IRFOS's Response

DeepSeek position (2026-08-07)	RFI-IRFOS response
Processing in China is direct collection under EDPB Guidelines 05/2021 para. 18, not a Chapter V transfer.	Citation verified as accurate. The relabelling leaves the physical location of the data and the exposure under Art. 7 of the PRC National Intelligence Law unchanged, and the policy mentions neither a named Art. 46 mechanism nor that risk.
Carrier SDKs apply to users with Chinese phone numbers, the Volcano SDK does not start for EU IP addresses.	H1 concerns provider onCreate() at process start, which precedes any login choice or IP check. The binary contains no gate on loading the code.
A DPIA and an LIA were drafted and evaluated.	Date, scope and reference were requested twice and not provided. Neither document is referenced in the public policy.
No statement on H1, H3, M1, M3.	Listed in the rebuttal and the follow-up as open.

Findings

C1: Core chat function routes EU user prompts to chat.deepseek.com, and the operator's own policy states Personal Data is processed and stored in the People's Republic of China

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 8.7
unqualified transfer destination confirmed by binary and by the operator's own policy

```
/api/v0/chat/completion
/api/v0/chat/continue
/api/v0/chat/edit_message
/api/v0/chat/history_messages
/api/v0/chat/regenerate
/api/v0/chat/resume_stream
/api/v0/chat_session/create
/api/v0/chat_session/delete_all
/api/v0/asr/ws
```

RFI-IRFOS blast-radius escalation: raised from HIGH/8.7 to CRITICAL because the affected processing is the core function of a mass-market consumer AI assistant. Every EU user's free-text prompts, which predictably include health, legal and personal disclosures, are processed in a third country with no named Art. 46 mechanism and no published transfer impact assessment. CVSS technical scope does not capture this population and content exposure.

Impact: Every prompt a user types leaves the device through /api/v0/chat/completion and its sibling endpoints on chat.deepseek.com. DeepSeek's current privacy policy states: "To provide you with our services, we directly collect, process and store your Personal Data in People's Republic of China." Binary and policy describe the same processing of the same data. The policy names no Art. 46 mechanism for it and does not address the compelled-disclosure duty of Art. 7 of the PRC National Intelligence Law. DeepSeek's reply of 7 August 2026 characterised the processing as direct collection under EDPB Guidelines 05/2021, paragraph 18, and not as a Chapter V transfer. RFI-IRFOS checked the citation and confirms it is accurate. The relabelling leaves the location of the data, and the legal regime that applies to it there, unchanged.

H1: Two ContentProviders initialise at process start, before any consent screen can render

MEDIUM, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N, 6.9 pre-consent initialisation on every install

```
<provider android:authorities="com.deepseek.chat.cn.fly.FlyProvider" android:exported
    ="false" android:multiprocess="true" android:name="cn.fly.FlyProvider"/>
<provider android:authorities="com.deepseek.chat.apm" android:exported="false" android
    :name="com.bytedance.frameworks.core.apm.contentprovider.MonitorContentProvider"/>
```

RFI-IRFOS blast-radius escalation: raised from MEDIUM/6.9 to HIGH because the initialisation applies to every install of a mass-market AI assistant before any consent is possible, and the providers belong to PRC-based SDK vendors. What these providers transmit in that window was not measured in this static pass.

Impact: cn.fly.FlyProvider (a Chinese carrier one-click-login SDK) and com.bytedance.frameworks.core.apm.contentprovider.MonitorContentProvider (ByteDance APM) are declared without an android:process override. Android instantiates declared providers during Application process creation, before the first Activity, on every install in every country. The only consent element found in the app is a single ”Agree” button. No CMP or IAB TCF component exists. DeepSeek’s reply of 7 August 2026 describes when the login feature activates. The provider onCreate() executes regardless of login method. This finding received no answer.

SDK	Vendor (as disclosed)	Binary evidence

H2: Eight-vendor Chinese third-party SDK chain, self-disclosed in DeepSeek's zh-CN compliance list and matched to the binary

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 8.7
binary and operator disclosure agree line for line

SDK	Vendor (as disclosed)	Binary evidence
SM SDK	Beijing Shumei Times Technology	com.ishumei.smantifraud.*, libsmsdk.so, fengkong-cloud.com
Growth Marketing Suite / APM	Beijing VolcanoEngine Technology	com.bytedance.applog.*, libvolc_log.so, volces.com
Mobile Number Authentication	China Mobile Internet	cmpassport.com
Unicom One-Tap Login	China United Network Communications	wosms.cn
Telecom Account Authentication	China Telecom Digital Life	i139.cn, 189.cn
Miaoverify	Shanghai Zhangzhi Tao Information Technology	cn.fly.* (attribution plausible, not certain)
WeChat Open SDK	Shenzhen Tencent Computer Systems	WXEntryActivity, open.weixin.qq.com

Impact: DeepSeek's own zh-CN third-party information sharing list names eight vendors, including Beijing Shumei Times Technology (device fingerprinting), Beijing VolcanoEngine Technology (ByteDance-affiliated analytics and performance monitoring) and three Chinese carrier authentication SDKs. Each resolves to classpaths, native libraries or live endpoints in the binary: com.ishumei.smantifraud.*, libsmsdk.so, com.bytedance.applog.*, com.bytedance.apm6.*, libvolc_log.so, apmplus.volces.com, gator.volces.com, cmpassport.com, wosms.cn and i139.cn. DeepSeek's reply states the carrier SDKs serve users with Chinese phone numbers and that the Volcano SDK does not initiate for EU IP addresses. The binary contains no region gate for loading the code, and the claim is not documented anywhere in the public policy.

H3: network_security_config.xml permits cleartext traffic app-wide and contradicts the manifest declaration

HIGH, CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 8.2 directly contradictory files, concrete http:// targets

```
<base-config cleartextTrafficPermitted="true">
  <trust-anchors><certificates src="system" /></trust-anchors>
</base-config>

hardcoded: http://fp-it-tracker.fengkongcloud.com
           http://castatic.fengkongcloud.com
           http://crbt.i139.cn
```

Impact: AndroidManifest.xml declares android:usesCleartextTraffic="false". The referenced network_security_config.xml sets <base-config cleartextTrafficPermitted="true"> with no domain-config overrides and no certificate pinning. The configuration file governs platform behaviour. Hardcoded http:// strings exist for the Shumei fingerprint tracker and a China Telecom domain. Whether those URLs are dereferenced without an upgrade to HTTPS requires a network capture and was not part of this static pass. This finding received no answer.

M1: Named-vendor disclosure exists only for zh-CN users; the en-US policy names no recipients

MEDIUM, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 6.9 transparency asymmetry between two language trees of one app

Impact: The app links to four dedicated compliance documents in the zh-CN tree, including the third-party information sharing list with eight named vendors and per-vendor data categories. The en-US tree has two documents and describes recipients only as categories of service providers. EU users of the identical app and identical SDK integrations receive the thinner disclosure. This finding received no answer.

M2: "Not designed or intended to process sensitive Personal Data" disclaimer against an unfiltered free-text chat interface with opt-out model training

MEDIUM, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.1 structural contradiction between policy text and product design

Impact: The policy disclaims processing of sensitive Personal Data, while the app's core input is an open text box with no client-side classification or redaction found in the binary. Model training on user content is governed by an opt-out, with legitimate interests cited as the legal basis. DeepSeek's reply states a DPIA and an LIA were drafted. Neither document, nor its date or scope, is referenced in the public policy or was shared in response to the follow-up request.

M3: Hardcoded SDK AppKey and AppSecret in AndroidManifest meta-data

MEDIUM, CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 6.3 plaintext secret pair extractable from the public APK

```
custom-AppKey    = 3b199b7a...
custom-AppSecret = 98c6a376...
custom-Https     = yes
```

Impact: The carrier one-click-login SDK is configured with a key and secret in plaintext manifest meta-data, readable by anyone who decompiles the public APK. Whether the vendor scopes the pair against abuse is unknown. Values are truncated in this public report. This finding received no answer.

L1: Age gate relies on self-declared birth date; effective minimum age 14

LOW, CVSS v4.0 AV:N/AC:H/AT:P/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 2.1 age assurance exists but is not verified

Impact: A date-of-birth prompt with a reject path exists. It is not verified against any authority, and no parental consent flow was found. Austria sets the digital consent age at 14, while several member states set 16.

Impact Analysis

C1 concerns the function every user touches. A prompt to a general-purpose assistant can contain a health question, a legal problem, a relationship detail or a political view, and the policy places that content in a jurisdiction whose national intelligence law obliges organisations to support state access. The report records what the binary and the policy establish and leaves the question of actual access to the supervisory authorities. H1 and H2 add device and network identifiers flowing to PRC-based analytics and anti-fraud vendors from the first launch. For an individual EU user, the practical consequence is a persistent device profile and a chat history held outside the protection of GDPR remedies.

The Complete Chain: Seven Messages, One Reply, Three Open Questions

Step 1, disclosure: On 2 July 2026 RFI-IRFOS sent the full findings to privacy@deepseek.com and to DeepSeek's Art. 27 EU representative (rep_deepseek@prighter.com), with the Austrian Datenschutzbehörde and the EDPS in CC, stating an embargo of 30 September 2026.

Step 2, follow-ups: Messages followed on 6 July, 17 July, 23 July and 31 July 2026, each restating the three questions.

Step 3, the reply: On 7 August 2026, 36 days after the disclosure and after four follow-ups, privacy@deepseek.com replied. The reply answered C1 with a legal argument (direct collection, EDPB Guidelines 05/2021 paragraph 18), answered H1 and H2 with an operational claim about when the login feature and the Volcano SDK activate, and stated that a DPIA and an LIA exist.

Step 4, rebuttal: The same day RFI-IRFOS replied, confirmed the EDPB citation as accurate, pointed out that H1, H3, M1 and M3 were not addressed, and asked three narrow questions: whether DeepSeek disputes that a declared ContentProvider executes onCreate() at process start, what disclosure EU users receive about compelled-access risk under Art. 7 of the PRC National Intelligence Law, and the date and scope of the DPIA and LIA.

Step 5, silence: A follow-up on 15 August 2026 repeated the three questions. No reply followed. The embargo date of 30 September 2026 passed with the questions unanswered.

Step 6, publication: This report publishes on 17 October 2026, 17 days after the embargo date and 63 days after the last RFI-IRFOS message, with the full record intact: seven messages sent, one reply received, three questions open.

Data Protection: Article by Article

Art. 44 and Art. 46 GDPR, third-country transfers: C1 and H2 describe processing in the PRC without a named transfer mechanism.

Art. 6 and Art. 7 GDPR, lawfulness and consent: H1 describes provider initialisation before the only consent element, a single Agree button.

Art. 32 GDPR, security of processing: H3 and M3 describe app-wide cleartext permission and a hardcoded SDK secret.

Art. 12, Art. 13 and Art. 14 GDPR, transparency: M1 describes named-vendor disclosure for zh-CN users only.

Art. 9 and Art. 35 GDPR, special categories and impact assessment: M2 describes the sensitive-data disclaimer against an unfiltered chat interface and the unreferenced DPIA.

Art. 8 GDPR, children: L1 describes a self-declared age gate.

Art. 5(2) GDPR, accountability: the operator carries the burden of demonstrating each of the above.

Regulatory & Legal Landscape

DeepSeek has an Art. 27 representative and no EU main establishment, so any supervisory authority in a member state where users are affected can act. The Austrian Datenschutzbehörde and the EDPS were in CC on the original disclosure and on later messages from 23 July 2026 and 31 July 2026 respectively. Fine exposure: Art. 83(5) GDPR applies to the transfer and consent issues in C1, H1 and H2, up to EUR 20,000,000 or 4 percent of total worldwide annual turnover, and Art. 83(4) applies to the Art. 32 and Art. 35 issues in H3, M2 and M3, up to EUR 10,000,000 or 2 percent. The EDPB Guidelines 05/2021 argument advanced by DeepSeek is a legitimate legal position on the Chapter V question. It does not answer the Art. 13 transparency requirement for recipients, and it does not address Art. 7 of the PRC National Intelligence Law.

Indicators of Compromise

Extracted from the production APK by static analysis only. No DeepSeek server, account or infrastructure was accessed. One passive HTTP header check was made against a first-party-declared hostname.

```
Host:       chat.deepseek.com (/api/v0/chat/*)
Providers:  cn.fly.FlyProvider, com.bytedance.frameworks.core.apm.contentprovider.
    MonitorContentProvider
Endpoints:  apmplus.volces.com, gator.volces.com, tab.volces.com, databyterangers.com.
    cn,
            castatic.fengkongcloud.com, captcha.fengkongcloud.cn, cmpassport.com,
    wosms.cn, i139.cn, e.189.cn
Native:     libsmsdk.so, libvolc_log.so, libapminsighta.so, libapminsightb.so
Secrets:    custom-AppKey 3b199b7a..., custom-AppSecret 98c6a376... (truncated)
```

Disclosure Timeline & Outcome

2026-07-02 Initial disclosure sent to privacy@deepseek.com and rep_deepseek@prighter.com, CC Datenschutzbehörde and EDPS. Embargo stated as 2026-09-30.

2026-07-06 Follow-up sent. No reply.

2026-07-17 Follow-up sent. No reply.

2026-07-23 Follow-up sent. No reply.

2026-07-31 Follow-up sent. No reply.

2026-08-07 privacy@deepseek.com replies: EDPB para. 18 argument on C1, operational claims on H1 and H2, DPIA and LIA stated to exist. RFI-IRFOS replies the same day with a rebuttal and three questions.

2026-08-15 Follow-up repeating the three questions. No reply.

2026-09-30 Embargo date reached with the three questions unanswered.

2026-10-17 This report published, 17 days after the embargo date. Record: seven RFI-IRFOS messages, one reply, zero of three questions answered.

Residual Risk & Recommendations

C1: Name the Art. 46 mechanism for the processing in the PRC, publish a transfer impact assessment that addresses Art. 7 of the PRC National Intelligence Law, and state the legal position in the en-US policy EU users receive.

H1: Defer initialisation of both providers until after an informed consent step, or remove them from EU builds, and introduce a CMP.

H2 and M1: Publish the eight-vendor list with data categories in every language version of the policy.

H3: Set `cleartextTrafficPermitted` to false, add domain-config pinning for chat.deepseek.com, and replace the three http:// endpoints.

M2: Publish the date, scope and reference of the DPIA and LIA, and document how the sensitive-data disclaimer is reconciled with free-text input and opt-out training.

M3: Rotate the SDK key and secret and move them out of the manifest.

L1: Review the age assurance mechanism against the consent age in each member state served.

Procedural: RFI-IRFOS remains open to a substantive answer to the three questions on record. It will be added to the public record next to the original findings, whichever entity provides it.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static root-level analysis of the published application using publicly available tooling. No DeepSeek servers, accounts or infrastructure were probed, apart from one passive HTTP header check against a first-party-declared hostname. Technical evidence is archived under chain of custody and will be provided to regulatory authorities on request. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF DS-2026-R1-001.